本报告来源于“慧博投研”，请勿外传!

华创证券 HUA CHUANG SECURITIES

证券研究报告

点评报告 2026 年 03 月 13 日

【点评报告】

量化看市场系列之八：OpenClaw 的安全防护指南

华创证券研究所

证券分析师：王小川

邮箱：wangxiaochuan@hcyjs.com

执业编号：S0360517100001

相关研究报告

《量化看市场系列之七：使用 OpenClaw 快速搭建 AI 助理团队》

2026-03-10

《量化看市场系列之六：OpenClaw 金融行业必备 Skills 推荐与实战应用》

2026-03-09

《量化看市场系列之五：如何叫你的 AI 更聪明、运行更有效率——Skills 的设置与使用》

2026-02-17

《量化看市场系列之四：使用“OpenClaw”搭建属于自己的私域 AI 助理》

2026-02-03

❖ **摘要**

2026 年 3 月 10 日，国家互联网应急中心（CNCERT）发布《关于 OpenClaw 安全应用的风险提示》。同日，工信部网络安全威胁和漏洞信息共享平台、央视新闻、腾讯网、搜狐等官媒集体报道 OpenClaw 安全风险。

先要说清楚一件事：OpenClaw 不是普通的聊天机器人。普通聊天机器人只能回复文字，OpenClaw 能干的事远不止这些：它具备 exec（直接执行系统命令）、web_fetch（访问任意网页）、read/write（读写文件系统）等一系列强大工具。这意味着，你的 AI Agent 拥有的权限，可能比你公司很多正式员工的权限都大。

OpenClaw 的安全性并非一个简单的二元结论，而是一个取决于实施者安全运维水平的变量。需要明确指出的是：**OpenClaw 在默认安装状态下确实存在较高的安全风险**。其核心设计赋予了 AI 模型执行代码、访问文件系统、操作系统调用等能力——这些功能在提供强大自动化的同时，也成为潜在的攻击面。若直接使用默认配置而未进行任何安全加固，系统将暴露于多种威胁之下。然而，**通过系统性的安全配置，OpenClaw 的风险可以降至可控范围**。本文论述的九项安全实践——从基线配置、网络隔离、沙箱机制到凭证管理等，构成了一个纵深防御体系，帮助有效防护潜在的安全威胁。

我们认为：**国家互联网应急中心（CNCERT）此次的预警并非禁止新技术的应用，而是为狂飙的 AI 应用踩下了一脚必要的刹车**。OpenClaw 这类具备强大行动力的 AI Agent 可能是未来的发展趋势之一，它的潜力巨大。**但在将“钥匙”交给 AI 之前，请务必先为它装上“安全带”和“安全气囊”。**

安全，是 AI 真正落地应用的基石。希望这篇研报能帮助大家更安全、更自信地拥抱 AI 的未来。

❖ **风险提示：**

网络安全是一个动态演进的领域，新的攻击手法和系统漏洞会不断出现。遵循本文的指南进行操作，并不能保证能够抵御所有现在未知或未来新出现的安全威胁。对于因新出现的安全问题或未遵循最佳实践而导致的任何损失，本文作者及相关方不承担法律责任。

未经许可，禁止转载

本报告来源于“慧博投研”，请勿外传!

目 录

一、OpenClaw 安全问题为什么突然被关注 4
二、OpenClaw 安全配置“十诫” 4
（一）权限最小化原则：别给 AI 发“万能钥匙” 4
（二）严格的输入验证与过滤：别让恶意命令变成“武器” 5
（三）网络访问控制：管住 AI 的“手” 5
（四）身份认证与访问控制：分清谁是谁，给不同的待遇 5
（五）安全审计与日志记录：让 AI 的每一步都有“监控录像” 6
（六）资源限制：给 AI “限流” 6
（七）沙箱与隔离技术：给 AI 盖个“玻璃房” 6
（八）敏感信息脱敏：别让 AI 记住“密码本” 6
（九）定期安全评估：像做体检一样，定期给 AI“查体” 6
（十）用户教育与透明化：把丑话说在前头 7
三、OpenClaw 安全落地实战 7
（一）基线基础安全配置（官方推荐） 7
（二）网络暴露防护（可选配置） 8
（三）沙箱配置（核心防护） 9
（四）利用安全工具进行恶意 Skills 防护 10
（五）多 Agent 隔离 11
（六）应急响应 12
（七）保持更新 12
四、总结 13
五、风险提示 14

本报告来源于“慧博投研”，请勿外传!

图表目录

图表 1 基线基础安全配置 7
图表 2 本地网络安全防护 8
图表 3 远程访问安全防护 8
图表 4 启用沙箱配置 9
图表 5 隔离沙箱网络 10
图表 6 多 agent 配置建议 11
图表 7 更换令牌设置 12

在过往的量化报告中，我们或运用多种指标对个股、指数及 ETF 进行择时判断，或从形态视角对不同类别资产展开分析，并基于此构建配套的量化产品，供客户参考使用。《量化看市场》系列报告致力于进一步拓展量化方法在市场研究中的应用：或围绕市场热点提供量化视角的解读，或分享原创性的思考结论，以此实现从提供产品策略到直接输出观点的转变，从而更高效地辅助投资决策。本系列报告所涉及的相关模型，我们将在 https://xingtai.pro/opinion 网站持续更新专题内容与最新研判，欢迎访问。

一、OpenClaw 安全问题为什么突然被关注

2026 年 3 月 10 日，国家互联网应急中心（CNCERT）发布《关于 OpenClaw 安全应用的风险提示》。同日，工信部网络安全威胁和漏洞信息共享平台、央视新闻、腾讯网、搜狐等官媒集体报道 OpenClaw 安全风险。

先要说清楚一件事：OpenClaw 不是普通的聊天机器人。普通聊天机器人只能回复文字，OpenClaw 能干的事远不止这些——它具备 exec（直接执行系统命令）、web_fetch（访问任意网页）、read/write（读写文件系统）等一系列强大工具。这意味着，你的 AI Agent 拥有的权限，可能比你公司很多正式员工的权限都大。

试想一下这个场景：你给 AI 装上了命令行终端、文件读写能力、网络访问功能，然后把它拉进了一个 50 人的飞书群。那么，你可能刚刚把服务器的“钥匙”交给了群里的每一个人。

国家互联网应急中心明确指出，OpenClaw 在默认配置或不当配置下存在较高的安全风险，可能引发以下严重后果：

- 命令注入攻击：如果用户输入未经过滤，攻击者可以通过精心构造的对话，诱导 AI 执行恶意系统命令。例如：“提示词注入”风险。
- 敏感信息泄露：具备文件读写能力的 AI，可能被越权访问服务器上的配置文件、数据库凭证、源代码等核心敏感数据。
- Server-Side Request Forgery (SSRF)：web_fetch 功能可能被利用来探测内网、攻击内部系统，或发起对外部目标的恶意请求。
- 权限滥用：在多人协作场景（如群聊）中，任何成员都可能通过 AI 间接获得超出其应有范围的系统权限。

但这不代表 OpenClaw 不能用——就像开车需要系安全带，用 OpenClaw 也需要正确配置。

二、OpenClaw 安全配置“十诫”

（一）权限最小化原则：别给 AI 发“万能钥匙”

别用“管理员”账号跑 AI：千万不要用你电脑或服务器的最高权限账号（比如 Linux 的 root、Windows 的 Administrator）来运行 OpenClaw。这就好比你把家里大门的钥匙、每个房间的钥匙都交给了保安。正确的做法是：单独创建一个“普通员工”级别的低权限账号（比如就叫 ai_user），只给它干活需要的那点权力。Windows 和 Mac 系统也一样操

作。这是能解决大部分安全问题的最根本办法。

圈定 AI 的活动范围：别让 AI 能随便翻你电脑上的所有文件。用 Docker 容器或者系统自带的沙箱功能，把它的活动范围圈在一个特定的、不包含敏感信息的小文件夹里（比如 /tmp/ai_workspace/）。它只能在这个“小房间”里玩，就翻不了你的保险柜。

命令“白名单”：如果非得让 AI 执行系统命令（比如查个时间），千万别让它什么命令都能跑。列一个“白名单”，也就是它只能执行你规定好的那几条无害命令（比如 date 看时间，ls 看某个特定文件夹里的文件列表），其他的一概拒绝。

（二）严格的输入验证与过滤：别让恶意命令变成“武器”

让 AI 做“选择题”而非“问答题”： 设计交互方式时，最好让用户选“动作”（比如选“查看文件”），然后填“参数”（比如输入“文件名”）。由程序把这两个信息安全地组合起来。不要让 AI 直接把用户说的一大段话，当成交给它执行的命令。这就好比点餐，你是让客人从菜单上选，而不是让他对着厨房喊“给我炒个菜，随便放点啥”。

给用户输入“洗个澡”： 对所有用户输入的内容进行检查和过滤，把那些能用来搞破坏的特殊符号（比如 ; | && $() 这些）统统清理掉，防止坏人通过输入“有毒”的话，让 AI 去执行额外的恶意命令。**尤其是 skills 的安全，安装前一定需要关注 skills 网站上 VirusTotal 与 OpenClaw 的评级，当评级是 benign 的时候，才可以阅读后安装。**

（三）网络访问控制：管住 AI 的“手”

给 AI 的网络上个“防火墙”： 在服务器上设置好防火墙规则，限制 OpenClaw 这个程序能访问哪些网络。如果需要它调用外面的 API（比如 OpenAI 的接口），就只放行那几个必要的网址（比如 api.openai.com），其他的互联网网站一律禁止访问。

严禁“摸内网”： 绝对禁止 AI 的 web_fetch（访问网页）功能去访问你们公司的内部网络地址(比如 IP 是 10.x.x.x, 172.16.x.x, 192.168.x.x 开头的，还有它自己本机 127.0.0.1)。这是防止利用 AI 当“跳板”攻击公司内部系统的关键。

干脆只让去指定地点： 如果业务很明确，AI 只需要访问一两个网站，那最好配置一个“网址白名单”，只准 OpenClaw 去这几个地方。

（四）身份认证与访问控制：分清谁是谁，给不同的待遇

给每条指令“贴个标签”： 在群里用 AI 时（比如飞书群、钉钉群），系统需要能识别出每条指令是谁发的。

根据不同的身份，给不同的 AI 工具使用权限。普通员工可能只能用 AI 查天气、问百科。只有主管或管理员才能用 AI 去“查看服务器日志”这种敏感操作。

（五）安全审计与日志记录：让 AI 的每一步都有“监控录像”

详细记录所有用户问了什么、AI 调用了什么工具、执行了什么命令、访问了哪个网址、以及最后返回了什么结果。

设置监控和告警，一旦发现有人短时间内疯狂让 AI 执行命令，或者反复尝试读取敏感文件（比如 /etc/passwd），系统要能立刻发出警报，并自动限制这种行为。

日志里别留“密码”： 记录日志的时候，要对密码、密钥、身份证号这类敏感信息进行打码处理（比如显示成 ******），防止日志文件本身泄密。

（六）资源限制：给 AI“限流”

限制“使唤”次数： 限制每个用户或整个 AI，在单位时间内（比如一分钟）最多能调用多少次工具，防止有人恶意刷指令把服务器累垮。

干不完就“掐断”： 给所有工具调用设置一个超时时间。比如让 AI 去访问一个网页，如果 5 秒钟还没反应，就强制结束，防止恶意指令（比如访问一个故意延迟的地址）长期占用资源。

限制“读写量”： 限制 AI 一次性最多能读多大的文件，最多能写多大的文件，防止有人让 AI 读一个几百 G 的大文件把内存撑爆，或者写满你的硬盘。

（七）沙箱与隔离技术：给 AI 盖个“玻璃房”

用 Docker“关起来”： 强烈建议把 OpenClaw 放在 Docker 这类容器里运行。Docker 就像一个透明的“玻璃房”，把 AI 的程序、它能看到哪些文件、能连哪些网络都严格隔离在房间里，就算它真被人攻破了，也跑不出这个房间去危害整个操作系统。

用一次，清一次： 每次和 AI 的对话结束后，就直接销毁这个容器，里面产生的所有临时数据都一起消失。下一次对话，再给它创建一个全新的、干净的“房间”。这样能保证每一次对话都是干净的，不会把上次的“脏东西”留到下次。

（八）敏感信息脱敏：别让 AI 记住“密码本”

把密码“藏”在环境里： AI 需要用的 API 密钥、数据库密码等敏感信息，绝对不要直接写在代码或配置文件里。应该通过环境变量的方式注入。同时要确保 AI 没办法通过执行命令（exec）或读文件（read）的方式，把环境变量里的密码给读出来。

给返回结果“打码”： 在 AI 把结果返回给用户之前，设置一道“检查岗”，把结果里可能泄露的 IP 地址、内网域名、密钥关键词等信息自动屏蔽掉。

（九）定期安全评估：像做体检一样，定期给 AI“查体”

纳入“体检名单”：把 OpenClaw 这个服务，加入到公司定期的漏洞扫描计划里，用扫描

工具自动给它“体检”。

请“专业医生”把脉：在正式上线之前，或者做了重大功能更新之后，邀请公司的安全团队，或者请专业的安全人员，对 AI 应用进行一次专门的“渗透测试”，模拟真正的黑客会怎么攻击它，看看有没有漏洞。

（十）用户教育与透明化：把丑话说在前头

挂个“警示牌”：在 AI 的交互界面上，明确告诉所有用户：“请注意，本 AI 可以执行命令/读取文件，为了安全，请勿输入任何密码、个人隐私或恶意指令。”

写“免责声明”：明确列出使用规则，并声明如果有人恶意利用 AI 进行攻击、破坏或窃取数据，公司保留追究其责任的权利。

三、OpenClaw 安全落地实战

这是一份关于如何安全配置和运行 OpenClaw 的实战指南参考。可按照以下步骤逐一实施，以构建一个多层防御的安全体系。

（一）基线基础安全配置（官方推荐）

这是所有安全措施的基石。请检查并修改 OpenClaw 安装路径下的 openclaw.json 文件，确保包含以下配置：

图表 1　基线基础安全配置

```
{
  // 1. Gateway 配置：控制 API 访问
  "gateway": {
    "mode": "local",
    "bind": "loopback",                // ✅ 只允许本地访问 (127.0.0.1)
    "auth": {
      "mode": "token",
      "token": "替换为长随机令牌"       // ✅ 生成命令: openclaw doctor --generate-gateway-token
    }
  },

  // 2. 会话配置：隔离用户数据
  "session": {
    "dmScope": "per-channel-peer"      // ✅ 每个用户的私聊会话相互隔离
  },

  // 3. 工具配置：限制 AI 的能力
  "tools": {
    "profile": "messaging",            // ✅ 仅启用消息类工具
    "deny": ["group:automation", "group:runtime", "group:fs"], // ❌ 禁用自动化、运行时、文件系统工具组
    "fs": {
      "workspaceOnly": true            // ✅ 文件操作仅限于工作区
    },
    "exec": {
      "security": "deny",
      "ask": "always"                  // ✅ 执行命令始终需要人工审批
    },
    "elevated": {
      "enabled": false                 // ❌ 禁用权限提升
    }
  },

  // 4. 渠道配置：控制外部消息入口
  "channels": {
    "whatsapp": {
      "dmPolicy": "pairing",           // ✅ 仅允许已配对的用户发起私聊
      "groups": {
        "*": {
          "requireMention": true       // ✅ 在群组中，只有被 @提及 才响应
        }
      }
    }
  }
}
```

资料来源：华创证券

配置后的效果：

- Gateway：只能通过本机（127.0.0.1）访问。
- 认证：所有 API 请求都需要携带一个强令牌。
- 会话隔离：不同用户在私聊中的会话数据互相不可见。
- 工具安全：禁用了所有高危工具（如文件读写、命令执行、自动化脚本）。
- 文件操作：严格限制在预设的工作区内。
- 命令执行：任何执行命令的请求都需要人工确认。
- 群聊交互：AI 只在被 @提及 时才响应，避免噪音和误触发。

（二）网络暴露防护（可选配置）

根据使用场景，选择合适的网络配置，原则是尽量不暴露到公网。

- 场景一：仅本地使用（最安全）---AI 和你运行在同一台电脑上。

图表 2 本地网络安全防护

```
{
  "gateway": {
    "bind": "loopback",    // 绑定到 127.0.0.1
    "port": 18789,
    "auth": { "mode": "token", "token": "xxx" }
  }
}
```

资料来源：华创证券

- 场景二：远程访问（通过 Tailscale 安全隧道）---你需要在其他设备（如手机、另一台电脑）上访问本机的 AI。

图表 3 远程访问安全防护

```
{
  "gateway": {
    "bind": "loopback",    // 仍保持本地绑定
    "auth": { "mode": "token", "token": "xxx" },
    "tailscale": {
      "mode": "serve",     // ✅ 使用 Tailscale Serve 暴露服务
      "allowFrom": ["your-device.tailnet-name.ts.net"] // ✅ 仅允许特定的 Tailscale 设备访问
    }
  }
}
```

资料来源：华创证券

绝对禁止的配置：

- bind: "0.0.0.0"：这会监听所有网络接口，直接将服务暴露在公网上。
- Tailscale Funnel：这会通过 Tailscale 将服务公开到互联网。
- 在路由器上为 OpenClaw 端口做端口转发。

- 场景三：必须公网访问（极度不推荐）

如果万不得已，必须采取额外的加固措施：

修改默认端口：编辑 ~/.config/systemd/user/openclaw-gateway.service，**将 --port 18789 改为一个不常用的高位端口。**

配置防火墙白名单：

仅允许你的常用 IP

访问新端口 ufw allow from 你的常用 IP 地址 to any port 新端口

（三）沙箱配置（核心防护）

沙箱是将 AI 的工具执行进程放入 Docker 容器中运行，即使 AI 被恶意利用，也无法直接影响你的宿主机。
启用沙箱的配置：

图表 4 启用沙箱配置

```
{
  "agents": {
    "defaults": {
      "sandbox": {
        "mode": "all",              // ✅ 所有会话都强制进入沙箱（可选 "non-main" 仅非主会话）
        "scope": "agent",           // ✅ 每个 Agent 拥有一个独立的容器
        "workspaceAccess": "none"   // ✅ 沙箱内的 AI 无法访问宿主机的工作区
      }
    }
  }
}
```

资料来源：华创证券

沙箱网络隔离：
进一步隔离沙箱的网络，防止 AI 通过内部网络进行攻击。

图表 5 隔离沙箱网络

```
{
  "agents": {
    "defaults": {
      "sandbox": {
        "docker": {
          "network": "openclaw-sandbox"          // ✅ 使用独立 Docker 网络
        },
        "browser": {
          "network": "openclaw-sandbox-browser", // ✅ 浏览器进程也使用独立网络
          "cdpSourceRange": "172.21.0.1/32"      // ✅ 限制调试协议的访问来源
        }
      }
    }
  }
}
```

资料来源：华创证券

（四）利用安全工具进行恶意 Skills 防护

Skill Vetter 是一款专门用于 AI 代理技能安全审计的 OpenClaw 技能，能够在安装任何技能前扫描代码、检查权限申请、识别潜在恶意行为，帮助用户从根源上规避风险。

Skill 安装地址：https://clawhub.ai/spclaudehome/skill-vetter

除了 Skill Vetter，还有专门的命令行安全扫描工具 ClawSec，可在安装前自动检测技能：

npm install -g clawsec

clawsec config set auto-scan true

在选择和安装 Skills 前，需要检查三项内容：

第 1 层：VirusTotal 安全报告核查

OpenClaw 已与 Google 旗下 VirusTotal 达成合作，所有 ClawHub 技能都会生成唯一 SHA-256 哈希值并交叉验证。在 Skill 详情页即可查看扫描结果：

- 显示"flagged"（标记恶意）：直接放弃安装
- 标注"warning"（可疑）：结合其他两步进一步验证
- 无标记且每日重新扫描：优先选择

第 2 层：GitHub 仓库真实性核验

- 需要提供 GitHub 仓库链接，无仓库或仅提供网盘下载的直接忽略。
- 最近更新时间需在 6 个月内，长期未维护的技能可能存在兼容性与安全漏洞。
- 优先选择核心团队成员或高星项目维护者发布的插件。

- 仓库仅含 SKILL.md 文件+一段 curl 命令的，大概率是恶意套件，立即拒绝

第 3 层：SKILL.md 关键章节精读

重点查看"Prerequisites"（前置要求），出现以下特征直接判定为高风险：

- 要求通过 curl | bash 下载外部文件
- 强制安装"helper tools"辅助工具
- 提供密码保护的 zip 包

（五）多 Agent 隔离

如果有多人（或不同用途）使用同一个 OpenClaw 实例，需要进行严格隔离。

核心原则：

- 每人一个独立 Agent
- 每人一个独立工作区
- 为公开访问的 Agent 禁用所有危险工具
- 最佳实践：为每个人运行独立的 Gateway 实例。

为不同用户创建独立的 Agent 建议配置：

图表 6 多 agent 配置建议

```
{
  "agents": {
    "list": [
      { // 个人 Agent：功能完整，方便使用
        "id": "personal",
        "workspace": "~/.openclaw/workspace-personal",
        "sandbox": { "mode": "off" }        // 自己用，为了方便可以关闭沙箱
      },
      { // 家人 Agent：限制权限，保障安全
        "id": "family",
        "workspace": "~/.openclaw/workspace-family",
        "sandbox": {
          "mode": "all",
          "workspaceAccess": "ro"           // ✅ 对工作区只读
        },
        "tools": {
          "allow": ["read"],                // ✅ 只允许读取
          "deny": ["write", "exec", "browser"] // ❌ 禁止写入、执行、浏览器
        }
      },
      { // 公开 Agent：功能极度受限
        "id": "public",
        "workspace": "~/.openclaw/workspace-public",
        "sandbox": { "mode": "all", "workspaceAccess": "none" },
        "tools": {
          "allow": ["whatsapp", "telegram"],  // ✅ 仅允许收发消息
          "deny": ["read", "write", "exec", "browser", "cron", "gateway"] // ❌ 禁用所有其他工具
        }
      }
    ]
  },
  // 将不同的消息渠道绑定到不同的 Agent
  "bindings": [
    { "agentId": "personal", "match": { "channel": "whatsapp", "accountId": "personal" } },
    { "agentId": "family", "match": { "channel": "whatsapp", "accountId": "family" } }
  ]
}
```

资料来源：华创证券

（六）应急响应

一旦发现可疑行为，立即执行以下步骤。

- 第一步：遏制（立即切断风险）

```
# 停止 Gateway
pkill -f "openclaw gateway"
# 或停止 macOS App
```

切断网络暴露：修改配置文件，确保 gateway.bind 为 "loopback"，并关闭任何隧道服务。

冻结访问：在配置中临时设置 dmPolicy: "disabled"，并移除 allowFrom 中的所有 IP 或设为 "*"。

- 第二步：轮换凭证

更换 Gateway 令牌

图表 7 更换令牌设置

```
openclaw doctor --generate-gateway-token
vim ~/.openclaw/openclaw.json  # 更新 gateway.auth.token
openclaw gateway restart
```

资料来源：华创证券

更换所有 API 密钥：包括 WhatsApp、Slack、Discord、以及所有 AI 模型的 API 密钥。

- 第三步：审计（查找原因）

```
查看日志
tail -f /tmp/openclaw/openclaw-*.log

查看会话记录
ls ~/.openclaw/agents/*/sessions/*.jsonl

检查配置变更
git diff ~/.openclaw/openclaw.json # 如果用 git 管理

重新审计
openclaw security audit --deep
```

（七）保持更新

关注官方渠道：及时关注 OpenClaw 的官方公告、GitHub Release 或安全邮件列表。

定期更新：定期更新 OpenClaw 到最新版本，以获取最新的安全补丁和功能改进。

四、总结

OpenClaw 安全吗？我们的答案是：风险可控，关键在于配置。

OpenClaw 的安全性并非一个简单的二元结论，而是一个取决于实施者安全运维水平的变量。需要明确指出的是：

OpenClaw 在默认安装状态下确实存在较高的安全风险。其核心设计赋予了 AI 模型执行代码、访问文件系统、操作系统调用等能力——这些功能在提供强大自动化的同时，也成为潜在的攻击面。若直接使用默认配置而未进行任何安全加固，系统将暴露于多种威胁之下。

然而，**通过系统性的安全配置，OpenClaw 的风险可以降至可控范围**。本文前述的九项安全实践——从基线配置、网络隔离、沙箱机制到凭证管理——构成了一个纵深防御体系，帮助有效防护潜在的安全威胁。

针对企业用户，我们有一些额外的建议：

1. 基础设施隔离

独立部署环境：建议使用独立的虚拟私有服务器（VPS）或物理服务器进行部署，严格与员工个人工作站的开发环境、办公网络隔离。避免因 AI Agent 安全问题导致企业内网横向移动风险。

网络边界控制：将 OpenClaw 部署在特定的安全子网中，通过防火墙策略严格限制其与其他核心业务系统的网络通信。

2. 审计与监控体系

开启完整审计日志：在配置文件中设置 logging.redactSensitive: false（需确保符合数据合规要求），记录完整的操作日志，包括 API 调用、工具执行、文件访问等。

SIEM 系统集成：配置 OpenClaw 的日志输出，通过 Webhook 将实时日志发送至企业安全信息与事件管理平台，实现安全事件的集中监控与告警。

3. 安全测试与风险管理

定期渗透测试：将 OpenClaw 纳入企业定期渗透测试范围，重点关注其作为 AI Agent 的独特攻击面，例如提示词注入、工具滥用、沙箱逃逸等。

第三方安全评估：在上线前，委托专业安全团队进行全面的安全评估和代码审计。

购买网络安全保险：作为风险转移的最终手段，考虑购买覆盖 AI 系统特定风险的网络安全保险。

我们认为：**国家互联网应急中心（CNCERT）此次的预警并非禁止新技术的应用，而是为狂飙的 AI 应用踩下了一脚必要的刹车**。OpenClaw 这类具备强大行动力的 AI Agent 可能是未来的发展趋势之一，它的潜力巨大。但在将“钥匙”交给 AI 之前，请务必先为它装上“安全带”和“安全气囊”。

安全，是 AI 真正落地应用的基石。希望这篇研报能帮助大家更安全、更自信地拥抱 AI 的未来。

五、风险提示

网络安全是一个动态演进的领域，新的攻击手法和系统漏洞会不断出现。遵循本文的指南进行操作，并不能保证能够抵御所有现在未知或未来新出现的安全威胁。对于因新出现的安全问题或未遵循最佳实践而导致的任何损失，本文作者及相关方不承担法律责任。

本报告来源于“慧博投研”，请勿外传!

金融工程组团队介绍

组长、首席分析师：王小川

同济大学管理学博士。2017 年加入华创证券研究所。

研究员：洪远

华南理工大学金融硕士。2023 年加入华创证券研究所。

助理研究员：刘依凡

上海财经大学金融统计博士。2024 年加入华创证券研究所。

华创证券机构销售通讯录

地区	姓名	职务	办公电话	企业邮箱
北京机构销售部	张昱洁	副总经理、北京机构销售总监	010-63214682	zhangyujie@hcyjs.com
	张菲菲	北京机构副总监	010-63214682	zhangfeifei@hcyjs.com
	张婷	北京机构销售副总监		zhangting3@hcyjs.com
	刘懿	副总监	010-63214682	liuyi@hcyjs.com
	侯春钰	资深销售经理	010-63214682	houchunyu@hcyjs.com
	顾翎蓝	资深销售经理	010-63214682	gulinglan@hcyjs.com
	刘颖	资深销售经理	010-66500821	liuying5@hcyjs.com
	阎星宇	销售经理		yanxingyu@hcyjs.com
	车一哲	销售经理		cheyizhe@hcyjs.com
	吴昱颖	销售经理		wuyuying@hcyjs.com
深圳机构销售部	张娟	副总经理、深圳机构销售总监	0755-82828570	zhangjuan@hcyjs.com
	张嘉慧	资深销售经理	0755-82756804	zhangjiahui1@hcyjs.com
	王春丽	资深销售经理	0755-82871425	wangchunli@hcyjs.com
	王越	高级销售经理		wangyue5@hcyjs.com
	汪丽燕	销售经理	0755-83715428	wangliyan@hcyjs.com
	温雅迪	销售经理		wenyadi@hcyjs.com
	胡丁琳	销售经理		hudinglin@hcyjs.com
	付雅琦	销售经理		fuyaqi@hcyjs.com
	许馨匀	销售助理		xuxinyun@hcyjs.com
上海机构销售部	许彩霞	总经理助理、上海机构销售总监	021-20572536	xucaixia@hcyjs.com
	祁继春	上海机构销售副总监		qijichun@hcyjs.com
	黄畅	上海机构销售副总监	021-20572257-2552	huangchang@hcyjs.com
	吴俊	资深销售经理	021-20572506	wujun1@hcyjs.com
	张佳妮	资深销售经理	021-20572585	zhangjiani@hcyjs.com
	郭静怡	高级销售经理		guojingyi@hcyjs.com
	蒋瑜	高级销售经理	021-20572509	jiangyu@hcyjs.com
	吴菲阳	资深销售经理		wufeiyang@hcyjs.com
	朱涨雨	高级销售经理	021-20572573	zhuzhangyu@hcyjs.com
	李凯月	高级销售经理		likaiyue@hcyjs.com
	张豫蜀	销售经理	15301633144	zhangyushu@hcyjs.com
	刘雯	销售经理		liuwen@hcyjs.com
	章依若	销售经理		zhangyiruo@hcyjs.com
广州机构销售部	段佳音	广州机构销售总监	0755-82756805	duanjiayin@hcyjs.com
	王世韬	高级销售经理		wangshitao1@hcyjs.com
私募销售组	潘亚琪	机构服务部总经理助理	021-20572559	panyaqi@hcyjs.com
	汪子阳	副总监	021-20572559	wangziyang@hcyjs.com
	江赛专	副总监	0755-82756805	jiangsaizhuan@hcyjs.com
	汪戈	副总监	021-20572559	wangge@hcyjs.com
	宋丹玓	高级销售经理	021-25072549	songdanyu@hcyjs.com
	赵毅	销售经理		zhaoyi@hcyjs.com

本报告来源于“慧博投研”，请勿外传!

华创行业公司投资评级体系

基准指数说明:

A 股市场基准为沪深 300 指数，香港市场基准为恒生指数，美国市场基准为标普 500/纳斯达克指数。

公司投资评级说明:

强推：预期未来 6 个月内超越基准指数 20%以上;
推荐：预期未来 6 个月内超越基准指数 10%－20%;
中性：预期未来 6 个月内相对基准指数变动幅度在-10%－10%之间;
回避：预期未来 6 个月内相对基准指数跌幅在 10%－20%之间。

行业投资评级说明:

推荐：预期未来 3-6 个月内该行业指数涨幅超过基准指数 5%以上;
中性：预期未来 3-6 个月内该行业指数变动幅度相对基准指数-5%－5%;
回避：预期未来 3-6 个月内该行业指数跌幅超过基准指数 5%以上。

分析师声明

每位负责撰写本研究报告全部或部分内容的分析师在此作以下声明:

分析师在本报告中对所提及的证券或发行人发表的任何建议和观点均准确地反映了其个人对该证券或发行人的看法和判断；分析师对任何其他券商发布的所有可能存在雷同的研究报告不负有任何直接或者间接的可能责任。

免责声明

。本公司不会因接收人收到本报告而视其为客户。

本报告所载资料的来源被认为是可靠的，但本公司不保证其准确性或完整性。本报告所载的资料、意见及推测仅反映本公司于发布本报告当日的判断。在不同时期，本公司可发出与本报告所载资料、意见及推测不一致的报告。本公司在知晓范围内履行披露义务。

报告中的内容和意见仅供参考，并不构成本公司对具体证券买卖的出价或询价。本报告所载信息不构成对所涉及证券的个人投资建议，也未考虑到个别客户特殊的投资目标、财务状况或需求。客户应考虑本报告中的任何意见或建议是否符合其特定状况，自主作出投资决策并自行承担投资风险，任何形式的分享证券投资收益或者分担证券投资损失的书面或口头承诺均为无效。本报告中提及的投资价格和价值以及这些投资带来的预期收入可能会波动。

本报告版权仅为本公司所有，本公司对本报告保留一切权利。未经本公司事先书面许可，任何机构和个人不得以任何形式翻版、复制、发表、转发或引用本报告的任何部分。如征得本公司许可进行引用、刊发的，需在允许的范围内使用，并注明出处为“华创证券研究”，且不得对本报告进行任何有悖原意的引用、删节和修改。

证券市场是一个风险无时不在的市场，请您务必对盈亏风险有清醒的认识，认真考虑是否进行证券交易。市场有风险，投资需谨慎。

华创证券研究所

北京总部	广深分部	上海分部
地址：北京市西城区锦什坊街 26 号恒奥中心 C 座 3A	地址：深圳市福田区香梅路 1061 号 中投国际商务中心 A 座 19 楼	地址：上海市浦东新区花园石桥路 33 号花旗大厦 12 层
邮编：100033	邮编：518034	邮编：200120
传真：010-66500801	传真：0755-82027731	传真：021-20572500
会议室：010-66500900	会议室：0755-82828562	会议室：021-20572522